CYBER4PEOPLE

A Deep Dive into Vulnerability Management in Automotive Cybersecurity

Dr. Jetzabel Maritza Serna Olvera

Automotive Cyber Security Academy, Salerno, 22/08/24

© www.cyber4people.com. All Rights Reserved.

About me

Dr. Jetzabel Serna
CEO, Founder@CYBER4PEOPLE

Appointed member of the **ENISA's European Cyber Security Skills Framework** Ad Hoc Working Group
*Academic lecturer Cybersecurity IU

- Cybersecurity Strategy - Robert Bosch GmbH
- Cybersecurity Advisor - Geely Auto Technical DE
- Cybersecurity Knowledge Manager – Continental
- Assistant Professor - Goethe University Frankfurt
- Senior Security Intelligence Expert - BDigital
- Security Researcher - esCERT-UPC,
- SW Tester – CoCoNet Group
- SW Engineer – H. Ayuntamiento de Tijuana

© www.cyber4people.com. All Rights Reserved.

ENISA ECSF

Profile Title	Cyber Incident Responder
Alternative Title(s)	Cyber Incident Handler Cyber Crisis Expert Incident Response Engineer Security Operations Center (SOC) Analyst Cyber Fighter /Defender Security Operation Analyst (SOC Analyst) Cybersecurity SIEM Manager
Summary statement	Monitor the organisation's cybersecurity state, handle incidents during cyber-attacks and assure the continued operations of ICT systems.
Mission	Monitors and assesses systems' cybersecurity state. Analyses, evaluates and mitigates the impact of cybersecurity incidents. Identifies cyber incidents root causes and malicious actors. According to the organisation's Incident Response Plan, restores systems' and processes' functionalities to an operational state, collecting evidences and documenting actions taken.
Deliverable(s)	• Incident Response Plan • Cyber Incident Report
Main task(s)	• Contribute to the development, maintenance and assessment of the Incident Response Plan • Develop, implement and assess procedures related to incident handling • Identify, analyse, mitigate and communicate cybersecurity incidents • Assess and manage technical vulnerabilities • Measure cybersecurity incidents detection and response effectiveness • Evaluate the resilience of the cybersecurity controls and mitigation actions taken after a cybersecurity or data breach incident • Adopt and develop incident handling testing techniques • Establish procedures for incident results analysis and incident handling reporting • Document incident results analysis and incident handling actions • Cooperate with Secure Operation Centres (SOCs) and Computer Security Incident Response Teams (CSIRTs) • Cooperate with key personnel for reporting of security incidents according to applicable legal framework

Key skill(s)	• Practice all technical, functional and operational aspects of cybersecurity incident handling and response • Collect, analyse and correlate cyber threat information originating from multiple sources • Work on operating systems, servers, clouds and relevant infrastructures • Work under pressure • Communicate, present and report to relevant stakeholders • Manage and analyse log files	
Key knowledge	• Incident handling standards, methodologies and frameworks • Incident handling recommendations and best practices • Incident handling tools • Incident handling communication procedures • Operating systems security • Computer networks security • Cyber threats • Cybersecurity attack procedures • Computer systems vulnerabilities • Cybersecurity-related certifications • Cybersecurity related laws, regulations and legislations • Secure Operation Centres (SOCs) operation • Computer Security Incident Response Teams (CSIRTs) operation	
e-Competences (from e-CF)	A.7. Technology Trend Monitoring B.2. Component Integration B.3. Testing B.5. Documentation Production C.4. Problem Management	Level 3 Level 2 Level 3 Level 3 Level 4

Source: https://www.enisa.europa.eu/topics/education/european-cybersecurity-skills-framework/

© www.cyber4people.com. All Rights Reserved.

Why Vulnerability Management?

F22 Fighter Jet
< 2 million

Google Chrome
~ 6.7 million

Boeing 787
~ 14 million

Windows 10
~ 50 million

Facebook
~ 62 million

Modern High-End Car
~ 100 million

Stakeholders

- OEMs
- Suppliers
- Third party services
- Regulators
- PSIRT/CERT
- Hackers/researchers
- Engineering teams
- Road users

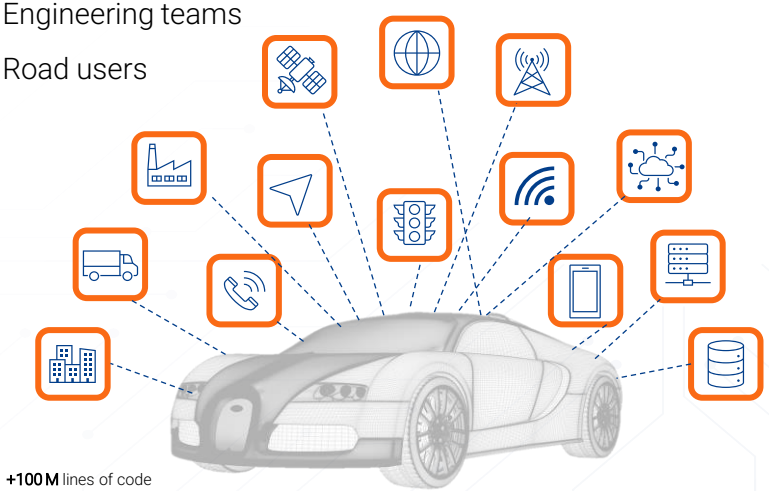


Image by PIRO from Pixabay

+100 M lines of code
1 defect per 10,000 lines of code*
At least 100 defects

Image source: https://www.keyfactor.com/education-center/automotive-iot-security/

One vulnerability, multiple products

January 12, 2022 04:35 AM

Teen hacker claims ability
Teslas worldwide

Hacker took control of Teslas in 13 countrie

Tesla Model S Hack Could Let Thieves Clone Key Fobs to Steal Cars

September 12, 2018 Mohit Ku

Despite having proper security me
the driving systems of its cars ag

Passwords For 540,000 Devices Leaked Online

CVE-2020-11896, CVE-2020-11897, CVE-20 11901: Ripple20 Zero-Day Vulnerabilities i Treck TCP/IP Libraries Disclosed

Ryan Seguin | Cyber Exposure Alerts
June 16, 2020 | 5 Min Read

Researchers discovered 19 new zero-day vulnerabilities in a TCP/IP s library developed by Treck. Dubbed Ripple20, the batch includes CVE 11901, which has the potential to allow control of an internet-connec device.

	Vendor	Status
9	Digi International	Affected
10	Eaton	Affected
11	Fujitsu	Affected
12	Green Hills Software	Affected
13	Hewlett Packard Enterprise	Affected
14	HP Inc.	Affected
15	Intel	Affected
16	Mitsubishi Electric Corporation	Affected
17	Ricoh Company Ltd.	Affected
18	Rockwell Automation	Affected
19	Schneider Electric	Affected
20	Teradici	Affected
21	Toshiba Corporation	Affected
22	Treck	Affected
23	Xerox	Affected
24	Zuken Elmic	Affected

Source: https://www.tenable.com/blog/cve-2020-11896-cve-2020-11897-cve-2020-11901-ripple20-zero-day-vulnerabilities-in-treck-tcpip

© www.cyber4people.com. All Rights Reserved.

Vulnerabilities in automotive

Most notorious CVEs still embedde

Nickname	CVE #
BleedingTooth	CVE-2020-12352
BleedingTooth	CVE-2020-12351
Sweet32	CVE-2016-2183
BleedingTooth	CVE-2020-24490
BlueBorne	CVE-2017-1000250
Spectre	CVE-2017-5715
Spectre	CVE-2017-5753
Drown	CVE-2016-0800
DirtyCow	CVE-2016-5195
BlueBorne	CVE-2017-1000251
Heartbleed	CVE-2014-0160

50,545

Most common packages that are over a decade old

zlib1.2.8	dnsmasq2.51
bzip21.0.6*	cracklib2.9.0
zlib1.2.3	alsa_lib1.0.27.2
libexif0.6.21	commons_logging1.1.0
libcap2.22*	alsa_utils1.0.27.2
httpcomponents_client4.0	expat2.1.0
jsip1.2.169	ppp2.4.5
iputils20121221	

* Has multiple CVEs with varying severities

ered in wolfSSL before 5.5.0. A fault injection attack on RAM via
ECDSA key disclosure. Users performing signing operations with
ch as in server-side TLS connections, might leak faulty ECC
gnatures can be processed via an advanced technique for ECDSA
.0 and later, WOLFSSL_CHECK_SIG_FAULTS can be used to
bility.)

5.2, if callback functions are enabled (via the
S flag), then a malicious TLS 1.3 client or network attacker can
-read on the heap of 5 bytes. (WOLFSSL_CALLBACKS is only
ing.)

5.1, malicious clients can cause a buffer overflow during a TLS
occurs when an attacker supposedly resumes a previous TLS
resumption Client Hello a Hello Retry Request must be triggered.
e required to contain a list of duplicate cipher suites to trigger
In total, two Client Hellos have to be sent: one in the resumed
d one as a response to a Hello Retry Request message.

ered in wolfSSL before 5.5.0 (when --enable-session-ticket is
version 5.3.0 is exploitable. Man-in-the-middle attackers or a
crash TLS 1.2 clients during a handshake. If an attacker injects
than 256 bytes) into a NewSessionTicket message in a TLS 1.2
client has a non-empty session cache, the session cache frees a
unallocated memory, causing the client to crash with a "free():
sage. NOTE: It is likely that this is also exploitable during TLS 1.3
a client and a malicious server. With TLS 1.3, it is not possible
an-in-the-middle.

Source: The state of Automotive Security in 2023 - CYBELLUM

© www.cyber4people.com. All Rights Reserved.

What is a vulnerability?

There is always a vulnerability

Weakness of software, hardware, or online service that can be exploited. *FIRST PSIRT framework*

A weakness of an asset or mitigation control that can be exploited by one or more threats. *ISO/SAE 21434*

© www.cyber4people.com. All Rights Reserved.

Root causes

- Incomplete security requirements
- Design flaws
- Implementation defects
- Misconfigurations
- Unexpected interactions
- …

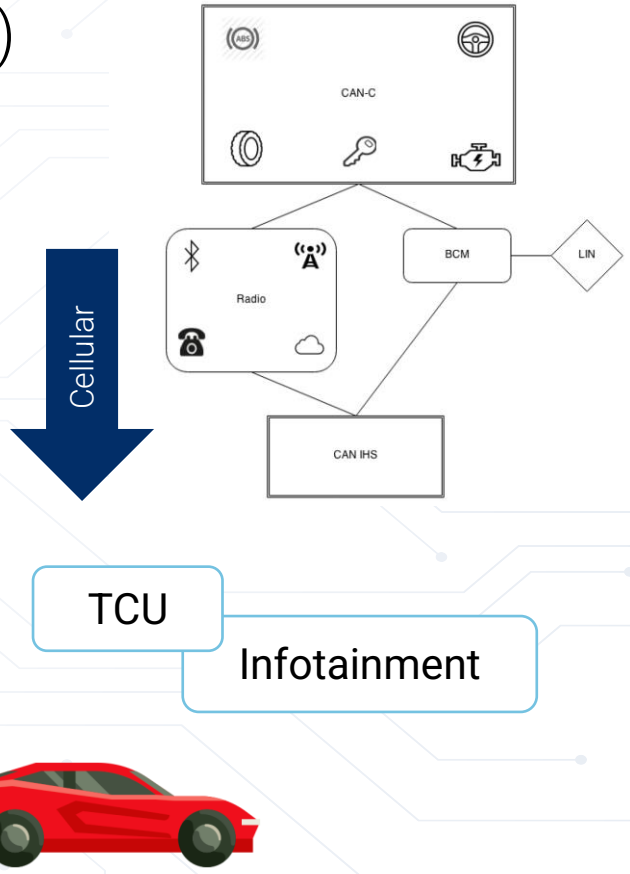
Security concept

This Photo by Unknown Author is licensed under CC BY-NC

© www.cyber4people.com. All Rights Reserved.

Jeep Hack

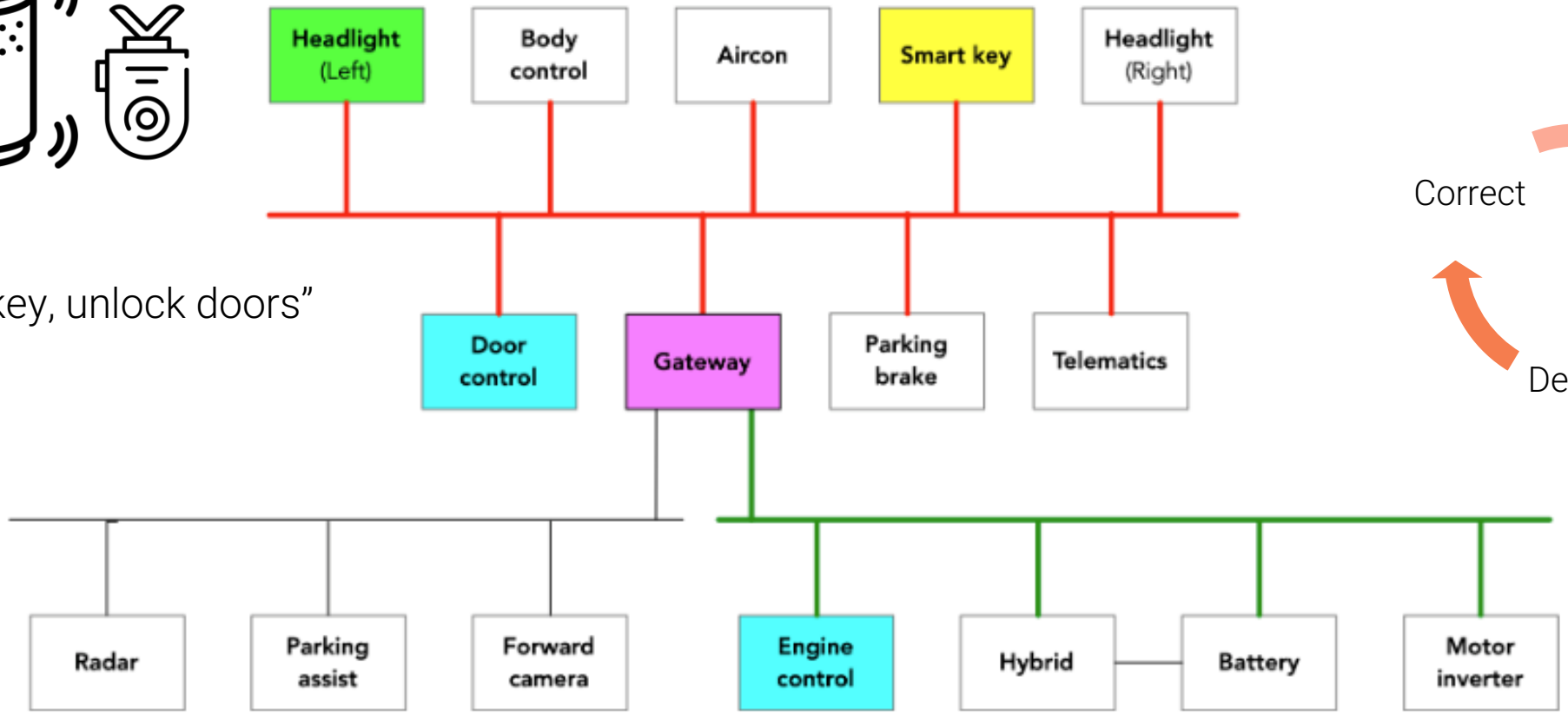
- Entry point– Infotainment (Uconnect : Wifi, Nav, Apps, Cel)
- Especially crafted messages (malicious payload)
- Result in a buffer overflow
- Arbitrary code execution to take control of the Uconnect
- FW Reprogramming (no authenticity verification) – ISOs published
- Access to CAN (internal CAN)
- Reverse engineering of CAN
- Sent of commands to other ECUs
- Taking control of the vehicle.

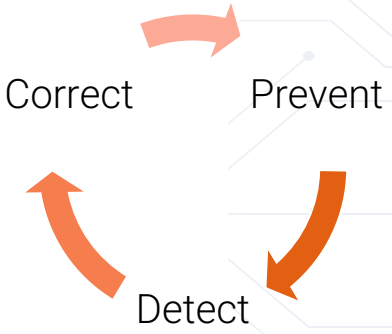


© www.cyber4people.com. All Rights Reserved.

Can Injection

Overly simplified diagram.





"Valid key, unlock doors"

"Valid key, unlock immobilizer"

Source: https://kentindell.github.io/2023/04/03/can-injection/

© www.cyber4people.com. All Rights Reserved.

Fleet Management

- OBD2 Dongle (aftermarket)
  - WiFi hotspot
  - GPS tracker
  - Anti-theft-services
  - Emergency call

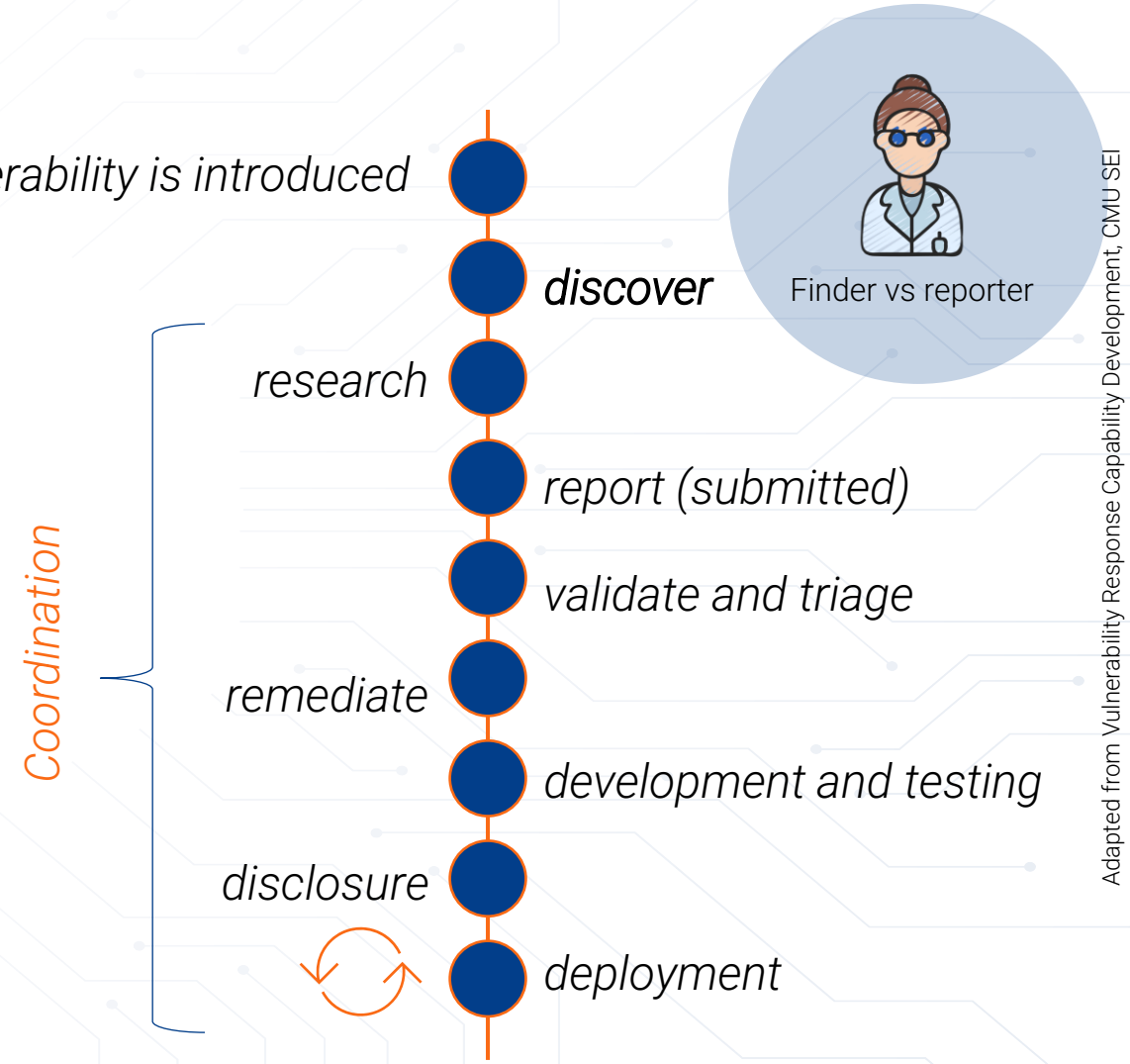
https://asrg.io/security-advisories/cve-2023-3028/

Censys, Shodan ….

Image source: https://www.youtube.com/watch?v=FycVqUvicJw

© www.cyber4people.com. All Rights Reserved.

Lifecycle

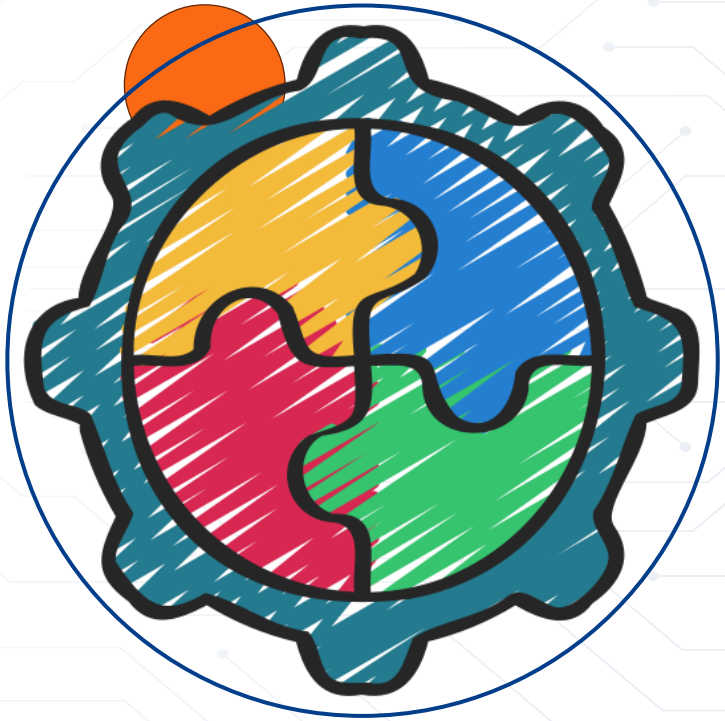


Vulnerability management starts when a vulnerability is discovered and/or submitted

© www.cyber4people.com. All Rights Reserved.

Discovery

- **Intake** of vulnerabilities
- Identification of **new** vulnerabilities
- Monitoring for **known** vulnerabilities
- Identify **unreported** vulnerabilities



Identify sources of vulnerability information

© www.cyber4people.com. All Rights Reserved.

Validation

Approve/confirm

Decline

Request for more information

Reporter

Respond

Track

SBOM

Does the vulnerability really affect your products?

© www.cyber4people.com. All Rights Reserved.

Triage: Scoring and ranking of vulns

ID(s)*, e.g., VU#-nnnnnn

Title /Description; alias(es)

Finder/reporter

Affected asset(s) -> version, type, vendors

Date(s): discovery, reported, modified, last update, release, remediation

Underlying weakness (category), e.g., CWE; attack vector (CAPEC).

Remediation + type

References

Status, lifecycle stage, TLP*

Scoring: vendor specific, CVSS

Exploitability, e.g., EPSS likelihood of exploits in the wild (attempted, exploited)

Severity /impact & other criteria (e.g., time to respond/ fix? Supply chain?)

Traffic Light Protocol
Exploit Prediction Scoring System (EPSS)
Common Weakness Enumeration (CWE)
Common Vulnerability Scoring System (CVSS)

Source: https://ossf.github.io/osv-schema/

© www.cyber4people.com. All Rights Reserved.

Scoring systems

CVEdetails.com
powered by SecurityScorecard

- Vulnerabilities
  - By Date
  - By Type
  - Known Exploited
  - Assigners
  - CVSS Scores
  - EPSS Scores
  - Search
- Vulnerable Software
  - Vendors
  - Products
  - Version Search
- Vulnerability Intel.
  - Newsfeed
  - Open Source Vulns
  - Emerging CVEs
  - Feeds
  - Exploits
  - Advisories
  - Code Repositories
  - Code Changes
- Attack Surface
  - My Attack Surface
  - Digital Footprint
  - Discovered Products
  - Detected Vulns
  - IP Search

Vulnerability Details : CVE-2022-42431

This vulnerability allows local attackers to escalate privileges on affected Tesla vehicles. An attacker must first obtain the ability to execute privileged code on the target system in order to exploit this vulnerability. The specific flaw exists within the bcmdhd driver. The issue results from the lack of proper validation of the length of user-supplied data prior to copying it to a buffer. An attacker can leverage this vulnerability to escalate privileges and execute arbitrary code in the context of root. Was ZDI-CAN-17544.

Published 2023-03-29 19:15:18 Updated 2023-04-08 01:57:14 Source Zero Day Initiative

View at NVD, CVE.org

Vulnerability category: Overflow Execute code

Exploit prediction scoring system (EPSS) score for CVE-2022-42431

Probability of exploitation activity in the next 30 days: 0.05%

Percentile, the proportion of vulnerabilities that are scored at or less: ~ 13 % EPSS Score History EPSS FAQ

CVSS scores for CVE-2022-42431

Base Score	Base Severity	CVSS Vector	Exploitability Score	Impact Score	Score Source
8.8	HIGH	CVSS:3.0/AV:L/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H	2.0	6.0	Zero Day Initiative
7.8	HIGH	CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H	1.8	5.9	NIST

CWE ids for CVE-2022-42431

CWE-120 Buffer Copy without Checking Size of Input ('Classic Buffer Overflow')
The product copies an input buffer to an output buffer without verifying that the size of the input buffer is less than the size of the output buffer, leading to a buffer overflow.
Assigned by: zdi-disclosures@trendmicro.com (Primary)

References for CVE-2022-42431

https://www.zerodayinitiative.com/advisories/ZDI-22-1407/
ZDI-22-1407 | Zero Day Initiative
Third Party Advisory;VDB Entry

Common Vulnerability Scoring System version 4.0

Technical severity != risk

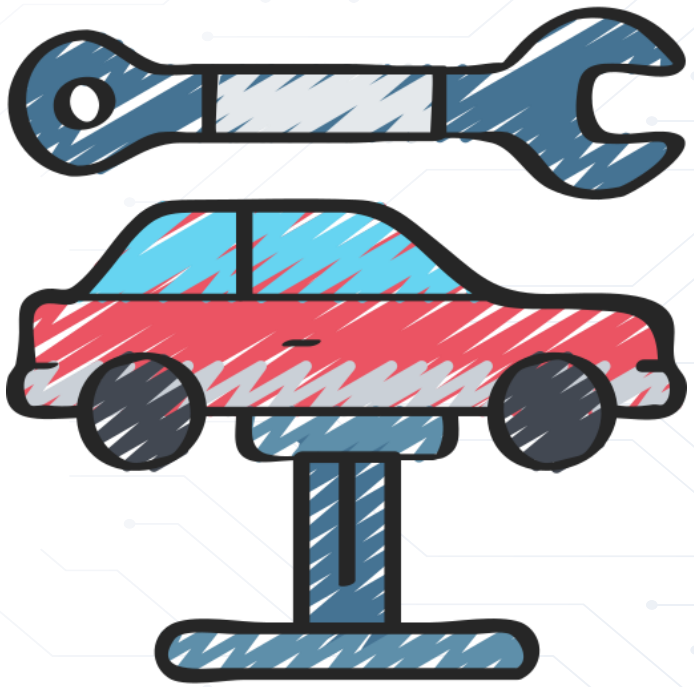
- P1: Critical
- P2: High
- P3: Medium
- P4: Low
- P5: Informational

Source: Budcrowd, CVSS First.org, CVEdetails.com

© www.cyber4people.com. All Rights Reserved.

Remediate & deploy

- Patch or workaround
- Time to fix estimation
- Approval processes
- Change management
- <u>Quality and testing</u>
- Cost of patches (OTA, recall)
- When to patch?
- Report back!



The vulnerability response team should be closely aligned with development and engineering teams.

© www.cyber4people.com. All Rights Reserved.

Disclosure

- Why to disclose?
- Who needs to know?
- What to disclose?
- When to disclose?

Why disclose in a security advisory?

What is a security advisory: info about the vulnerability and mitigation should be communicated to customers and/or the general public.

Give mitigation information to those who need it prior to exploitation.

Reassure customers and/or public that security issues are handled and taken seriously.

Participate in vulnerability ecosystem by publishing and tracking vulnerability information (typically with CVE IDs).

Encourage researcher participation in your vulnerability reporting or bug bounty program.

AUTO-ISAC
Automotive Information Sharing and Analysis Center

Image source: https://automotiveisac.com/

© www.cyber4people.com. All Rights Reserved.

Security Advisories

CSAF 2.0

- Give mitigation information to those who need it prior to exploitation.
- Reassure customers and/or public that security issues are handled and taken seriously.
- Participate in vulnerability ecosystem by publishing and tracking vulnerability information (typically with CVE IDs).
- Encourage researcher participation in your vulnerability reporting or bug bounty program

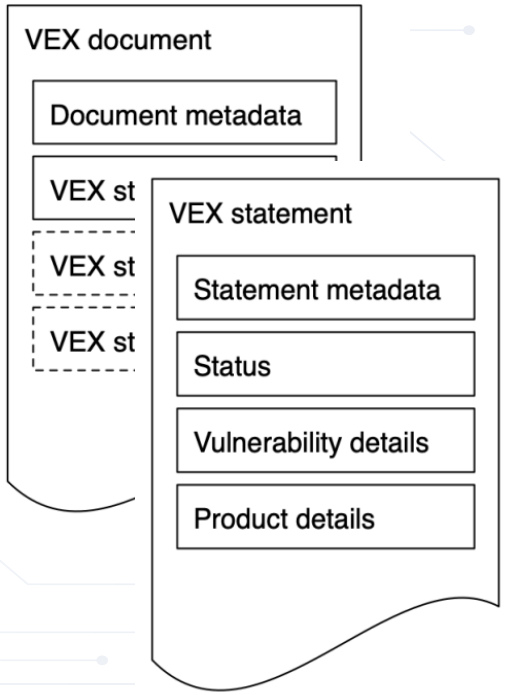
Security advisory: information about a vulnerability and its mitigation which is communicated to customers and/or the general public.

CSAF – Common Security Advisory Framework https://oasis-open.github.io/csaf-documentation/

© www.cyber4people.com. All Rights Reserved.

Vulnerability Exploitability eXchange (VEX)

- Collection of information that indicates the status of a SW or component with respect to a vulnerability (e.g., **affected or not affected**).
- Also applicable to HW, specifications, etc.
- Designed to support **automation**, i.e., machine readable format.
- Designed to integrate with SBOMs, vulnerability databases, security advisories.



*"A VEX document … indicates whether a product or products are affected by a **known vulnerability or vulnerabilities**", VEX Use Cases, CISA 2022*

SBOM – Software Bill of Materials

CISA VEX – Requirements https://www.cisa.gov/sites/default/files/2023-04/minimum-requirements-for-vex-508c.pdf

Source: https://www.cisa.gov/sites/default/files/2023-01/VEX_Use_Cases_Aprill2022.pdf

© www.cyber4people.com. All Rights Reserved.

Incident Response Management

Incident: situation in the **field** that can involve vulnerability **exploitation**

01
Preparation

02
Detection & Analysis

03
Containment/ Eradication

04
Post-incident Activities

© www.cyber4people.com. All Rights Reserved.

Who is typically involved?

Photo by Dylan Gillis on Unsplash

- PSIRT/CERT
- Quality
- Legal
- Communication / PR
- Engineering/technical Teams

© www.cyber4people.com. All Rights Reserved.

Challenges

- Inappropriate asset control
- Complexity and scalability
  - Number of affected components
  - Number of entities involved
  - Different regions; time zones
  - Conflicting requirements / agreements
  - Multiple maturity levels
- Much more than just CVEs
- Information sharing and quality of information
- Inadequate motivation to proactively discover vulnerabilities
- Assessment and consensus
- Vulnerability mitigation

© www.cyber4people.com. All Rights Reserved.

Best practices

- Establish appropriate asset control.
- Increase awareness, training and education in VM and IRM.
- Establish a network of VM champions.
- Define baseline vulnerability management requirements for suppliers.
- Establish requirements such as formats and minimum information required.
- Actively monitor and **look for vulnerabilities** (e.g., testing).
- Vulnerability information sharing is essential for a timely response.
  - Encourage sharing/exchange of vulnerability information.
  - Establish appropriate channels for communication.
  - Establish channels for coordinated disclosure.
- Automate!

© www.cyber4people.com. All Rights Reserved.

Links

- https://bugcrowd.com/vulnerability-rating-taxonomy
- https://cve.mitre.org/
- https://nvd.nist.gov/vuln/search
- https://www.cvedetails.com/cve/CVE-2022-42431/
- https://vuldb.com/?
- https://www.cisa.gov/known-exploited-vulnerabilities
- https://www.exploit-db.com/
- https://cwe.mitre.org/scoring/lists/2021_CWE_MIHW.html
- https://capec.mitre.org/data/definitions/3000.html
- https://www.first.org/cvss/v4.0/specification-document
- https://search.censys.io/search?resource=hosts&sort=RELEVANCE&per_page=25&virtual_hosts=EXCLUDE&q=mqtt
- https://ossf.github.io/osv-schema/#field-details
- https://docs.oasis-open.org/csaf/csaf/v2.0/os/csaf-v2.0-os.html

- SANS Institute - Implementing a vulnerability management Process (2013)
- SANS Institute - Incident Handler's Handbook (2020)
- ISO/IEC 30111_750274 Vulnerability Handling
- ISO/IEC 29147_746541 Vulnerability Disclosure
- ISO 27035 Security Incident Management
- The CERT Guide to Coordinated Vulnerability Disclosure
- CRR Supplemental Resource Guide – Vulnerability Management
- NIST Computer Security Incident Handling
- FIRST.org Product Security Incident Response Team (PSIRT) Services Framework v1.0 (2018)
- FIRST.org TRAFFIC LIGHT PROTOCOL (TLP) - FIRST Standards Definitions and Usage Guidance — Version 1.0
- CSAF - https://oasis-open.github.io/csaf-documentation/

Icons used in this presentation are from Flaticon.com under a licensed subscription.

© www.cyber4people.com. All Rights Reserved.

THANK YOU

WWW.CYBER4PEOPLE.COM